

Security Governance Assignment Answers

Part A - Cross functional governance responsibility model

1. Governance Roles and Responsibilities:

The Board sets the organization's risk appetite and provides oversight of management, while the CEO remains accountable for enterprise-level decisions. The CISO provides cybersecurity expertise and advice, the CRO provides independent challenge and aggregates risk across the enterprise, and business owners accept risks within their delegated authority. Operating teams are responsible for implementing and maintaining controls. This separation of responsibilities reflects the governance and oversight principles of NIST CSF 2.0 [1] and the integration of cybersecurity risk into enterprise risk management outlined in NIST IR 8286 Rev.1 [2].

- **Board of Directors / relevant Board committee:**

1. Approves risk appetite and security strategy within its corporate authority; it does not manage day-to-day security operations or incident response.
2. Provides independent oversight and challenge to the CEO, CISO, and CRO on material risks, control effectiveness, and resource adequacy. Receives regular risk reporting and immediate escalation of material incidents or risks.

- **CEO:**

1. Approves enterprise policy, significant risk acceptance and investment within Board delegation.
2. Consults CISO, CRO, Legal and Finance. Reports material exposure and decisions to the Board; resolves disputed cross functional priorities.

- **CISO:**

1. Sets security standards, proposes strategy and advises on technical exposure and response.
2. Consults IT and business owners on feasibility, CRO on risk and Legal on obligations. Reports metrics, exceptions and incidents to CEO and Board committee; does not accept every business risk.

- **CRO or enterprise Risk:**

1. Owns risk method, aggregation and independent challenge; advises on whether a proposal sits within appetite.
2. Consults CISO and business owners, records accepted and overdue risks, and reports an enterprise risk view to CEO and Board committee.

- **Legal, Privacy and Compliance:**

1. Interprets applicable notification, privacy and contractual duties; owns the internal legal assessment.
2. Needs verified incident facts from CISO/IT, impact from business and Finance, and advises executives on decision and deadline. Logs its reasoning and notifications.

- **Finance:**

1. Assesses affordability, estimates cost exposure and controls approval of expenditure.
2. Consults CISO on options and business units on disruption. Reports funding commitments and material financial impact to CEO/Board finance oversight.

- **Human Resources:**

1. Owns joiner, mover and leaver process, awareness delivery and employment discipline.
2. Consults Legal on sensitive employment steps and CISO/IT on access and evidence. Reports overdue removals and training results to governance committee.

- **IT and Technology Operations:**

1. Implements and runs access controls, logging, patches, backup and recovery under approved standards.
2. Consults CISO on exceptions, HR and business managers on access, and provides incidents, service impact and remediation evidence to the CISO and committee.

Business unit leaders are additional risk owners. They request access, provide operational impact, implement policy locally and accept lower-tier risk only under written delegation. A monthly Security Governance Committee chaired by the CISO joins all functions; an executive council chaired by the CEO decides issues above its authority.

2. RACI matrix:

R performs the work; A owns the defined decision or result; C advises before it; I is informed. BU means the relevant business unit owner. Each row has one A. The risk acceptance rows specify different scopes so they do not give one person authority over every risk.

Activity	Board	CEO	CISO	Risk	Legal	Fin.	HR	IT	BU
Security strategy approval	A	C	R	C	C	C	I	C	C
Enterprise cyber-risk acceptance	I	A	C	R	C	C		C	R
Information security policy approval	I	A	R	C	C	I	C	C	C
Major incident response governance	I	A	R	C	C	C	C	R	C
Regulatory breach notification	I	C	R	C	A			C	C
Privileged access approval			C	C			C	A	R
Significant third-party cyber-risk acceptance	I	A	C	R	C	C		C	R
Security awareness programme			R	C	C		A	I	C
Employee disciplinary action			C	C	C		A	C	R
Cybersecurity budget prioritisation	I	A	R	C	C	R		C	C
Board cyber-risk reporting	I	A	R	R	C	C			
Vulnerability remediation oversight			A	C				R	C
Business continuity governance	I	C	C	A	C	C	C	R	R

For privileged access, “IT = A” means a designated IT manager separate from the requester and implementer; an administrator never self-approves. For significant third-party risk, the CEO is A within delegated enterprise authority; routine supplier risk may instead be accepted by the authorised business owner. Legal owns the legal notification assessment, with the CEO consulted on the corporate response.

3. Segregation of duties and conflict resolution:

Conflict	Why it matters	Practical control
An IT administrator requests, approves and grants own privileged access.	Excess rights or fraudulent activity can escape review.	Business manager requests; separate IT approver authorises; access logs are reviewed by Security.
IT remediates a critical finding and marks its own work independently verified.	A weak fix can be closed without evidence.	IT implements; CISO checks evidence for material findings; Risk samples exceptions.
CISO identifies a material risk and accepts it alone.	The risk affects business goals and may exceed security delegation.	CISO assesses; CRO challenges; authorised BU/CEO accepts; Board oversees outside-appetite matters.
Business sponsor selects vendor and accepts its security weakness alone.	Commercial pressure can distort the decision.	Security review plus Risk and Legal advice; acceptance by authorised owner with a time limit.

4. Material cyber risk escalation:

Level and trigger	Timing and roles	Decision and evidence
1 Operational: contained local issue within approved tolerance.	Operations immediately log and triage; IT/BU owner with CISO support. Proposed target: same working day.	Treat locally; record affected assets, impact, severity, owner and review date.
2 Executive: high exposure, cross-unit disruption, suspected sensitive-data issue or beyond local authority.	CISO and CRO brief CEO, Legal, Finance and affected BU on the same day; active incident without delay.	CEO/council authorises resources or accepts within written delegation; record options and residual risk.

Level and trigger	Timing and roles	Decision and evidence
3 Material: outside enterprise appetite or likely material effect on services, money, privacy or reputation.	CEO promptly alerts Board leadership as soon as materiality is recognised; do not await a meeting.	Board provides oversight and any approval reserved to it; CEO implements; keep legal analysis, decisions, dissent and closure evidence.

Workflow: detection → unique incident/risk record → CISO and business impact assessment → CRO challenge and Legal duty check → compare to approved thresholds → Level 1 treatment or Level 2 executive decision → Level 3 Board oversight if material → action owner and due date → independent closure review. These timings are proposed internal targets, not regulatory deadlines. TechGlobal must define exact appetite and authority thresholds before adoption.

5. Cross functional failure scenario:

An employee leaves HR, but the leaver ticket is not sent to IT. The former employee retains access to a supplier portal holding personal records. IT sees unusual downloads but initially treats them as a routine alert. The business unit cannot tell Finance which contracts and payments are affected. Legal learns about the event days later and lacks reliable facts to assess notification duties. CRO has no single risk record, while the CEO and Board receive inconsistent accounts. Possible consequences are continued access, avoidable cost, contract disputes and missed legal deadlines where a duty applies; the scenario does not assert that any particular regulation has been breached.

1. HR owns a time-stamped leaver event, and IT automatically receives and confirms the disablement task; BU managers verify account lists.
2. IT alerts the CISO and Legal immediately when personal data may be involved and preserves logs and a clear incident timeline.
3. CRO maintains one incident/risk record with severity, uncertainty, impact, decision owners and review dates.
4. Finance and the business owner calculate service and contract impact for the executive briefing rather than waiting for a final forensic report.
5. Legal records jurisdiction-specific notification assessments and deadlines from verified facts; the CEO approves the corporate response within delegation.
6. The committee tests the joiner/leaver control monthly; overdue access removals and material incidents appear on the Board risk report.

Part B - The CISO and Board in contemporary governance

1. Role evolution and recommended model:

Over the past decade, the CISO has shifted from a mainly technical security leader to an enterprise risk adviser. Security still relies on identity controls, monitoring and incident response, but the CISO must now explain how these controls affect revenue, resilience, customers, privacy and strategy. NIST's Cybersecurity Framework, first released in 2014, added an explicit Govern function in 2024, covering risk strategy, roles, policy and oversight. This reflects a broader need for clear authority and accountability in cybersecurity decisions [1].

The CISO is not solely responsible for cyber risk. The Board sets risk appetite and oversees management; the CEO allocates resources and resolves trade-offs; the CRO provides the enterprise risk framework; and business leaders own operational risks. The CISO should translate technical findings into risk assessments, recommend treatments, report control performance and challenge exceptions. NIST IR 8286 Rev. 1 explains how cybersecurity risk information should feed into enterprise risk management rather than remain within the security function [2].

The CISO's reporting line also matters. Reporting only to IT may make it harder to challenge technology decisions because the same management chain controls project deadlines and budgets. Reporting to the CEO, with regular access to a Board committee, can improve escalation. However, independence also requires written escalation rights, documented risk acceptance, adequate control funding and periodic independent assurance. The Board should receive the CISO's assessment alongside the CEO's decision, including material disagreements.

Regulatory and investor scrutiny make documented decision-making increasingly important. Under US SEC rules, covered public companies must disclose annual information about Board oversight of cyber risk and management's role. They must also report material cyber incidents on Form 8-K within four business days after determining materiality, subject to the rule's conditions. This is a specific US securities requirement, not a general deadline for all organizations or breaches. The CISO provides facts and impact assessments, while executives and Legal determine materiality and disclosure requirements [3].

Board reporting should focus on actionable information: risks above tolerance, critical systems and dependencies, incidents and lessons, treatment progress, exceptions, owners, requested investment and evidence that controls work. Known impacts should be distinguished from plausible ones. Operational teams need detailed metrics, but excessive alerts can obscure Board decisions. The CISO should explain both control costs and the exposure they reduce, with Finance validating estimates and Risk challenging assumptions.

Digital dependence also makes resilience a business responsibility. Outages can disrupt payments, services, customer support and contractual obligations even without confirmed data theft. The CISO should coordinate exercises, supplier assurance, recovery priorities and communications with Legal, Finance, HR and operations. Business leaders must decide which services take priority, while Security provides technical facts and options.

The Uber case illustrates the importance of decision integrity. The US Department of Justice reported that former Uber CSO Joseph Sullivan was convicted in 2022 of obstruction and concealing a felony related to the company's response to its 2016 data breach. The government stated that the intrusion was concealed from lawyers and regulators while the company was subject to an FTC inquiry [4]. The case highlights the need to ensure incident facts reach Legal and authorized executives and that payments or settlements have auditable approval. It does not suggest that technical expertise is unimportant or that every CISO behaves similarly.

For a large organisation, I recommend that the CISO report administratively to the CEO, have scheduled and urgent access to the Board risk or audit committee, and lead a cross-functional security committee. The CRO should maintain the enterprise risk framework and challenge ratings; IT should own implementation; Legal should handle legal interpretation; Finance should assess impact and funding; HR should own workforce controls; and business leaders should own process risks. A written delegation schedule should define who can accept each level of risk, with Board oversight of material or out-of-appetite exposure [1][2].

Effectiveness should be measured through evidence rather than titles. Quarterly, the Board committee should review whether material risks were escalated promptly, exceptions were properly renewed or closed, independent testing confirmed critical remediation, and incident exercises produced corrective actions. Access without measurable follow-through is insufficient. These governance measures should be adapted to the organisation's laws, sector and risk appetite.

Part C - Change Healthcare cyberattack in 2024

1. Established facts and business impact:

UnitedHealth Group's 2023 filing described a cybersecurity programme led by its Chief Digital and Technology Officer and CISO, with Board oversight of cyber policy, resources, supplier risk and continuity. Because the filing followed the February 2024 attack, it describes the 2023 arrangements but does not prove that all controls worked at Change Healthcare [5].

In May 2024, CEO Andrew Witty told the Senate that attackers used compromised credentials to access a Change Healthcare Citrix portal without multifactor authentication on 12 February. They moved through the network, extracted data and deployed ransomware on 21 February. UnitedHealth disconnected affected systems and Witty said he approved a ransom payment. These details come from company testimony and are not independently verified here [6].

The disruption affected healthcare claims, pharmacy and payment processes. UnitedHealth's 2024 filing reported \$2.2 billion in direct response costs and \$867 million in Optum Insight business disruption. The \$640 million increase in medical spending was already included in the response costs and should not be double-counted [7]. HHS reported that approximately 192.7 million people were affected by 31 July 2025. This refers to individuals whose data was implicated, not necessarily those who experienced misuse [8].

2. Governance weaknesses and questions:

Evidence and status	Governance interpretation and improvement
Confirmed: the accessed remote portal lacked MFA [6].	A critical access exception escaped effective prevention. Require a complete remote-access inventory, named owner, mandatory MFA verification and a time-limited exception approved above the system owner.
Confirmed: UnitedHealth described Board/CISO oversight for 2023 [5], but the portal lacked MFA [6].	Inference: reporting and assurance did not ensure this particular control at the acquired business. Ask the Board committee to require exception evidence and independent sampling, not simply a policy statement.
Confirmed: attackers had nine days between access and ransomware, according to CEO testimony [6].	Inference: earlier detection or response might have limited exposure. Review actual logs, alert handling, escalation and lateral-movement controls; public evidence does not establish precisely what the security team saw.
Confirmed: containment required disconnecting Change systems and service disruption followed [6][7].	Inference: business-continuity dependence on a key platform increased sector-wide consequences. Test alternate claims and payment routes and assign cross-company recovery priorities.
Confirmed: affected-person analysis and notices took time and the count rose to 192.7 million [6][8].	Inference: data mapping and notification coordination are high governance priorities. Keep controller/processor responsibilities and a verified data inventory; no public record here proves an inventory was absent.
Confirmed: the CEO took the ransom decision and funds were advanced to providers [6][7].	Executive risk choices extended beyond IT. Maintain a crisis decision log with Legal, Finance, CISO, CRO and business input, and record why each option was chosen.

3. Accountability and consequences:

The Board provided oversight and challenge, especially on exceptions, supplier concentration and assurance. The CEO handled major crisis decisions and resources. The CISO/security team should assess controls, support containment and explain uncertainty, but available evidence does not show which security leader knew about the portal before the attack. Optum/Change business and technology teams owned the systems and recovery. Legal and privacy teams determined notification duties based on reliable facts. HHS notes that covered entities remain responsible for timely notice, even when a business associate handles it [8].

Known consequences include healthcare disruption, major response costs, business losses, a large number of affected people and notification duties [6][7][8]. Litigation, fines and final regulatory findings should not be assumed from these sources. The financial figures and HHS count also cover different periods and impacts.

4. Recommended governance changes:

1. Require quarterly evidence of MFA coverage across remote access, with any gap escalated to the CEO and Board committee according to materiality.
2. Give acquired businesses an integration plan with dated control milestones and independent verification before a system is treated as aligned to group standards.
3. Run detection and containment exercises against credential misuse and lateral movement, and record time to detect and contain.
4. Map critical service dependencies and test alternative claims/payment routes with customers and partners.
5. Create a crisis decision process with one incident record, verified data scope, Legal notification analysis, Finance impact and explicit executive approval.
6. Report open exceptions, overdue actions and test evidence to the Board; review whether the controls worked rather than only whether a policy existed.

Part D - Simulated NDPC incident analysis

1. Method and core results:

The accompanying workbook preserves INC0001–INC0180. It contains 100 records dated 2024 and 80 dated 2025. Counts use all 180 records. Cost figures add the workbook's estimated Cost_Impact_USD, not audited losses. Resolution_Time_Days is completed resolution time for Closed incidents and elapsed days for unresolved incidents; I report the closed-only average when discussing actual resolution. The simulated SLA_Breached field marks unresolved cases Pending, so breach rates use Closed records only.

Measure	Result
Total records and estimated cost	180 incidents; \$10,293,422 estimated cost
Open or In Progress	46 of 180 = 25.6%; On Hold is a separate 17 cases
Closed cases and SLA breaches	117 Closed; 54 exceeded simulated target = 46.2% of Closed
Highest type counts	Malware 28, Phishing 28, Data Leak 27
Highest mean cost per case	Insider Threat \$138,506 (n=5); Cloud Exposure \$94,846 (n=11); Third-Party Breach \$92,888 (n=6)

Incident type	Count	Share
Malware	28	15.6%
Phishing	28	15.6%
Data Leak	27	15.0%
Unauthorized Access	24	13.3%
DDoS	19	10.6%
Misconfiguration	19	10.6%
Cloud Exposure	11	6.1%
Credential Theft	9	5.0%
Third-Party Breach	6	3.3%
Insider Threat	5	2.8%
Lost Device	3	1.7%
Policy Violation	1	0.6%

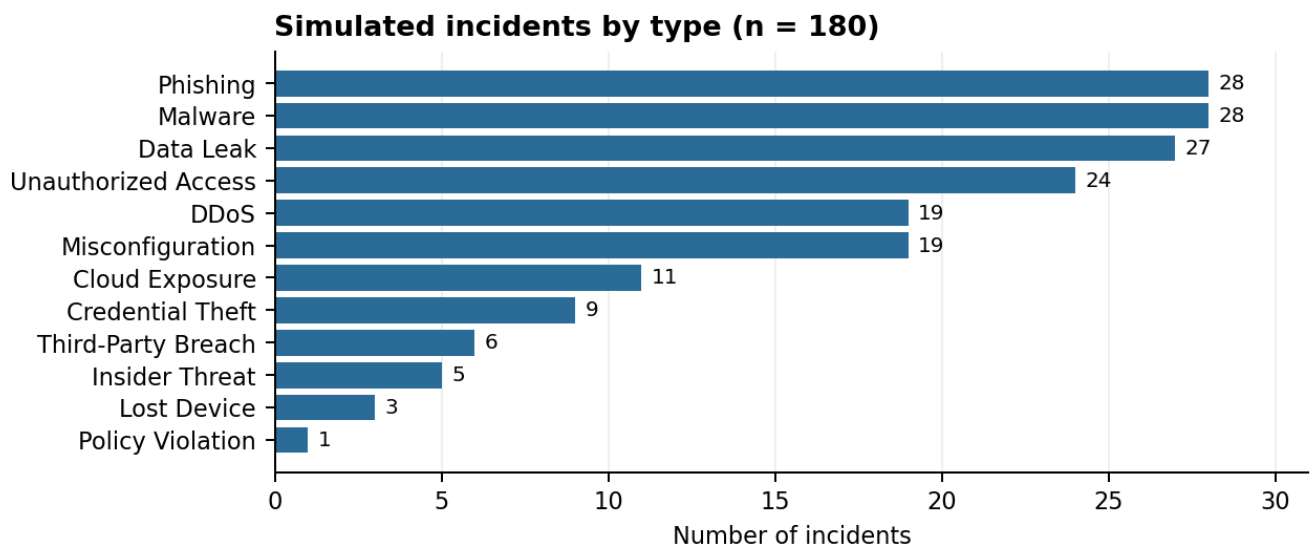


Figure 1. Count by incident type, all 180 simulated records. Workbook Summary contains an editable chart.

Severity	All cases	Mean elapsed days, all	Mean resolution days, Closed
Critical	20	9.8	10.8
High	53	12.7	10.9
Medium	80	14.7	12.5
Low	27	18.1	15.9

Department	Estimated cost (USD)	Response team	Estimated cost (USD)
Finance	\$1,756,282	Compliance	\$2,836,299
IT	\$1,725,965	DevOps	\$2,079,986
Operations	\$1,682,059	IT Security	\$1,763,143
HR	\$1,493,242	SOC	\$1,624,054
Legal	\$1,403,244	GRC	\$964,680
Cloud Operations	\$663,410	Incident Response	\$646,370
Student Services	\$643,730	IAM	\$283,670
Academic Services	\$617,870	Cloud Security	\$95,220
Research	\$307,620		

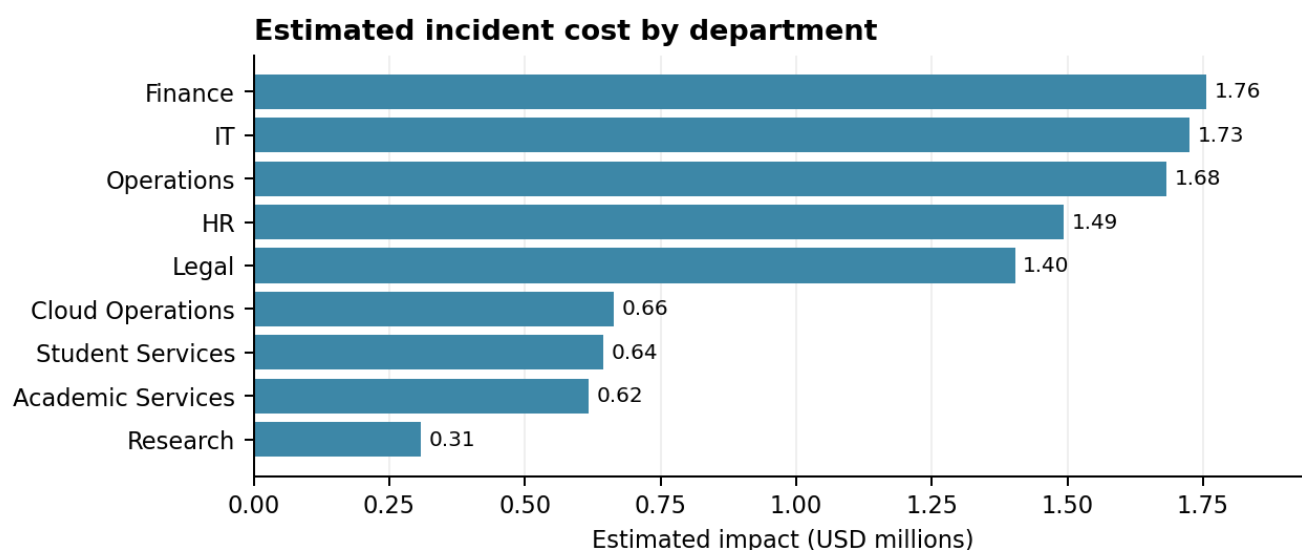


Figure 2. Estimated cost impact summed by department. This is a synthetic dataset; it does not represent actual NDPC losses.

D2 Governance patterns and limitations

Severity	Closed	SLA breaches	Breach rate
Critical	17	12	70.6%
High	34	25	73.5%
Medium	49	17	34.7%
Low	17	0	0.0%

Among responsible teams, IT Security has 15 breaches among 24 Closed cases (62.5%), DevOps has 13/25 (52.0%), SOC 11/24 (45.8%) and Compliance 8/22 (36.4%). The IAM team shows 1/1, but a sample of one is too small to rank as a reliable team-level pattern. Targets vary by severity (3, 7, 14 or 30 simulated days), so the breach rate is more informative than comparing raw completion days across teams.

The exposure field labels 56 cases “Privacy” and 33 “Contractual”; 14 of 30 IT cases, 10 of 26 Legal cases and 9 of 25 HR cases carry the Privacy label. “Privacy” is a data category for review. It does not establish that a reportable breach occurred or identify a law, jurisdiction or notification clock. Legal/Privacy should assess those details on the individual incident record.

Third_Party_Involved is Yes for 43 cases and No for 137. The corresponding mean estimated cost is \$73,700 versus \$52,002, about 41.7% higher in the Yes group. High or Critical shares are 18/43 (41.9%) versus 55/137 (40.1%). Executive or Board escalation counts also equal 18 and 55 because the escalation field is primarily derived from severity in this simulated dataset; it is not independent evidence that third parties cause escalation. The cost gap is an association, not causal proof, and the groups have different sizes.

Identity & Access Management should receive the first control review: 33 cases carry that domain, with \$1,932,469 estimated cost, the largest domain total, and 13 High/Critical cases. Its root cause labels include 9 Excessive privileges, 8 Compromised credentials and 7 Dormant account misuse. The CISO and IT should investigate access governance, privileged-access reviews, MFA and dormant accounts. Configuration Management is a second concern: 9 of 13 Closed cases breached SLA (69.2%), and its 19 records include 9 access-rule misconfigurations and 8 change-control failures. Neither dataset pattern proves which actual control failed.

The workbook combines 100 records from 2024 and 80 added records from 2025, and additional incident categories appear in the later records. It is unsafe to infer a real-world time trend or year-on-year change in risk from these simulated records. No row is evidence of a real NDPC incident.

3. Three priority messages to the CISO and Board:

Evidence and meaning	Owner and concrete action	Proposed success measure
54/117 Closed cases (46.2%) breached SLA; 12/17 Critical and 25/34 High. The response process needs scrutiny.	CISO accountable; IT Security, SOC and DevOps own treatment. Review priority routing and hold a weekly aged-case meeting.	Next quarter: reduce Critical/High closed-case breach share against this baseline; report numerator and denominator monthly.
IAM has 33 cases and \$1.93m estimated cost; 13 were High/Critical. Access risk crosses IT and business ownership.	CISO and IT implement MFA and dormant-account/privilege reviews; HR and BU leaders confirm leaver and approval events.	Monthly: share of inventoried privileged/remote accounts with MFA, and number of overdue dormant-account removals, with targets approved by management.
Third-party Yes cases average \$73,700 vs \$52,002; severity shares are similar. More expensive incidents warrant targeted supplier review.	BU supplier owner accountable for risk; CISO/Risk review critical suppliers and test recovery and access restrictions.	Quarterly: critical suppliers assessed and overdue remediation count; track incident cost by supplier involvement with group size.

The targets above are proposed indicators. The brief gives no existing thresholds or budgets, so the Board and executive team should approve numerical targets after reviewing capacity and risk appetite. The supporting workbook supplies formulas, source IDs and two editable charts used for these statements.

References and verification notes

[1] NIST, **The NIST Cybersecurity Framework 2.0 (2024)**. <https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf>

[2] NIST, **IR 8286 Rev. 1, Integrating Cybersecurity and Enterprise Risk Management (2025)**.
<https://csrc.nist.gov/pubs/ir/8286/r1/final>

[3] US SEC, **Cybersecurity Risk Management, Strategy, Governance, and Incident Disclosure, small entity compliance guide (2023)**. <https://www.sec.gov/resources-small-businesses/small-business-compliance-guides/cybersecurity-risk-management-strategy-governance-incident-disclosure>

[4] US Department of Justice, **Former Chief Security Officer of Uber Convicted of Federal Charges (5 Oct 2022)**.
<https://www.justice.gov/usao-ndca/pr/former-chief-security-officer-uber-convicted-federal-charges-covering-data-breach>

[5] UnitedHealth Group, **2023 Form 10-K, Item 1C Cybersecurity (filed 28 Feb 2024)**.
<https://www.sec.gov/Archives/edgar/data/731766/000073176624000081/unh-20231231.htm>

[6] Andrew Witty, **Testimony to US Senate Committee on Finance (1 May 2024)**.
<https://www.finance.senate.gov/download/0501-witty-testimony&download=1>

[7] UnitedHealth Group, **2024 Form 10-K, Change Healthcare Cyberattack discussion (filed 2025)**.
<https://www.sec.gov/Archives/edgar/data/731766/000073176625000063/unh-20241231.htm>

[8] US HHS Office for Civil Rights, **Change Healthcare incident FAQ (updated 13 Aug 2025)**. <https://www.hhs.gov/hipaa/for-professionals/special-topics/change-healthcare-cybersecurity-incident-frequently-asked-questions/index.html>

Declaration of AI Assistance - Artificial intelligence (AI) tools were used in the preparation of this assignment to assist with research, summarization, and language editing. The content was reviewed and critically evaluated by the author, who takes full responsibility for the accuracy, originality, and final content of the work.

Excel Data File:

https://docs.google.com/spreadsheets/d/1-n5jLHfE-vvX3NI4x3Ndk_kxyjiyCNV3/edit?gid=27247564#gid=27247564